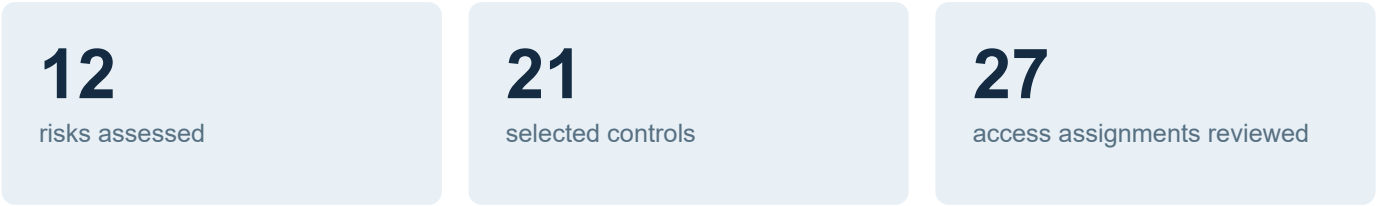


Protecting customer trust

ISO/IEC 27001 implementation planning

7 September 2026 | Version 1.0 | 25-person cloud software company

CaseCo Cloud needs to answer enterprise security questions with defensible evidence. This case study prioritizes customer access, reliable recovery and safer releases. It designs selected ISMS elements and completes one access-review exercise on synthetic records.



BASELINE RISK / 1 SEPTEMBER 2026



2 Critical 7 High 2 Moderate 1 Low

PRIORITIES FOR MANAGEMENT

- 01

Contain privileged-access exposure
R02: score 20, Critical. Review unnecessary permissions, require strong authentication and preserve justified administration. Platform Lead owns T02, due 7 October.
- 02

Demonstrate that recovery works
R05: score 20, Critical. Run an isolated restore and check data integrity against proposed 8-hour recovery and 24-hour data-loss targets. Platform Lead owns T05, due 7 October.
- 03

Close the access-process gaps
R01 and R03: High. Sample corrections are verified, but recurring leaver and role-change checks remain planned. Head of Support owns T01/T03, due 21 September.

Immediate action: the CEO and risk owners must confirm containment, authority and resources for High/Critical risks at day 0. Completion dates do not defer that decision.

From a sample to a working process

The exercise verifies three permission corrections. Sustained control operation, technical testing and risk acceptance remain separate work.

ACCESS REVIEW / COMPLETED IN SYNTHETIC RECORDS

AR027 / CA01	Departed employee account disabled.
AR004 / CA02	Unapproved repository Administrator changed to Developer.
AR024 / CA03	Sales access changed from Agent to approved Viewer.
AR011 / retained	Valid, independently approved cloud Administrator retained.

27 original records were retained for comparison; 24 assignments were unchanged. Systemic actions CA01-CA03 remain planned and their effectiveness is untested.

90-DAY IMPLEMENTATION SEQUENCE

Days 1-30	Access workflow, privilege, credentials and restore evidence. Gate: 7 October.
Days 31-60	Devices, suppliers, incident response, resilience, releases and people records. Gate: 6 November.
Days 61-90	Repeat tests, measure objectives, reassess targets and plan wider ISMS work. Gate: 6 December.

OPEN MANAGEMENT DECISIONS

Remaining High targets: R02 privileged compromise, R07 unsafe releases and R10 secret exposure each retain a target score of 10. Additional treatment or justified, time-limited acceptance needs the CEO and risk owner; no such acceptance is asserted.

Accepted in simulation: R12, the separate public brochure site, remains Low at 4. Review by 6 December or sooner if sensitive functions or greater dependency are added.

Implementation limits: the 21-control SoA is partial. Full requirements verification, obligations, approvals, technical tests, internal audit and management review remain open. Estimated targets are not measured risk reduction. This is not a certification conclusion.

REFERENCE FRAMEWORK

ISO/IEC 27001:2022 2024 amendment NQA public implementation guide